

Ciclo de negócio no contexto da Cibersegurança

Mod 5. Sessão 1

CISO – Considerações finais

Plano de estudos

9 sessões, totalizando 35 horas de curso, com cinco módulos principais

1.	2.	3.	4.	5.
Estado da Arte e modelo estratégico CISO	<i>Framework</i> SbD e mapa de dependências	Risco de <i>3rd Party</i> e <i>Vendor Management</i>	Gestão <i>3rd Party</i> e a visão colaborativa	Desafios na Era da IA
O tema da confiança na NIS2	Sec. by Design (SbD)	Boas práticas TPRM	ISO 27001 e ISO 27036	IA riscos e ameaças
Modelo de decisão do CISO	<i>Frameworks</i> de trabalho	Política, controlos e <i>Cloud</i>	Requisitos de gestão; controlos	IA GRC e 3rd Party
Caso InterMed 1	Caso InterMed 2	Caso InterMed 3	Caso InterMed 4	Caso InterMed 5

Quiz

Exemplos

Artefactos

Casos

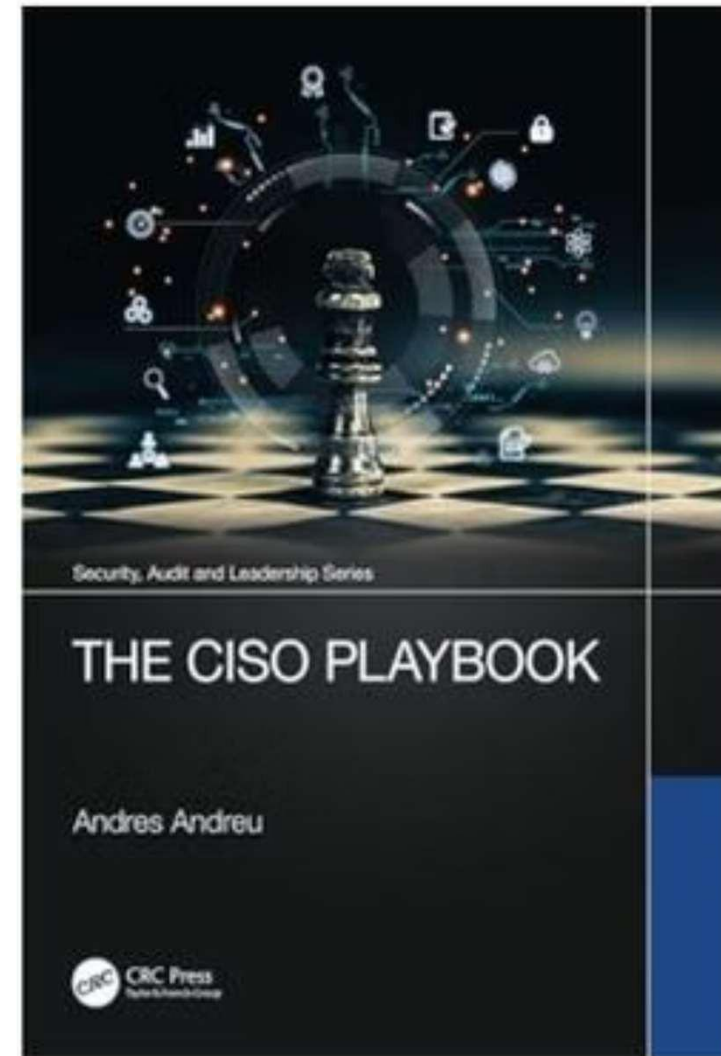
CISO Playbook (considerações finais)

a Nível Organizacional no Contexto da
Cibersegurança

The CISO Playbook

Considerações reais para gestores de cibersegurança — tanto os que estão a emergir como os que procuram crescer.

Adaptado de Andres Andreu — CRC Press



O que é um CISO?



O papel é dinâmico e em constante evolução, exigindo um elevado nível de adaptabilidade.

"A CISO is the ultimate guardian of an organization's digital assets — requiring executive leadership, technical knowledge, strategic vision, and effective communication skills."

O CISO deve:

- Entender a complexidade de **equilibrar requisitos de segurança com objetivos de negócio**
- Aplicar **boas práticas e gerir o risco**
- Promover uma **cultura de sensibilização e foco no fator humano**
- Garantir **conformidade regulatória**.

Posicionamento de gestão

Exige uma mentalidade específica e a aceitação de que o mundo empresarial está em permanente estado de fluxo – VUCA.

Visão e Gestão do conhecimento

Eliminar resistências, aceitar a volatilidade e definir uma visão clara e flexível para si e para a equipa – promovendo a aprendizagem.

Compreensão Situacional

Tornar-se especialista sobre ambiente macro e micro. Conhecer o negócio em profundidade através da Análise Situacional e relação com Clientes, Parceiros e Fornecedores.

Clareza

Comunicação clara e colaboração saudável, especialmente em situações complexas e caóticas.

Agilidade

Liderar sem ditar. Abraçar diferentes ideias e promover flexibilidade à medida que as condições mudam.

Enquadrar a Posição

Questões-chave a colocar:

→ **Posicionamento do papel**

É visto como função de TI ou como membro da equipa executiva? É consultado em decisões de M&A ou investimentos estratégicos?

→ **Tipos de CISO**

Operacional, Compliance/Risco, Steady State, Transformacional, Pós-Breach ou Field — cada perfil serve contextos organizacionais distintos.

→ **Gestão do Risco**

Quem aceita ou rejeita risco?

Existe um comité ERM?

Há um registo de riscos de cibersegurança?



Compreender o contexto da Organização

Nos primeiros 30 dias, o CISO deve agir com foco e estrutura. O objetivo é ganhar perspectiva e construir parcerias estratégicas.

1

Análise da Superfície de Ataque e do “Centro de Gravidade”

Identificar os ativos mais críticos e mapear os vetores de exposição da organização.

2

Implementar Métricas Básicas

As métricas provam o valor dos programas de segurança junto do C-Suite e do *board*

3

Segurança como Preocupação de Negócio

Quando a gestão entende que o risco *cyber* se traduz em risco de negócio, torna-se mais recetiva a apoiar e financiar iniciativas de segurança.

4

Desenvolver um Plano

Criar um plano de gestão do risco, atuando como ponto central de recolha de dados e comunicação com stakeholders internos e externos.

Cadeia de Fornecimento & TPRM



Risco na Cadeia de Fornecimento

- O TPRM avalia riscos associados a fornecedores, parceiros e prestadores de serviços

Third Party Risk Management (TPRM)

Os riscos típicos incluem:

- **Financeiro** — instabilidade do terceiro impacta operações
- **Segurança** — acesso a dados e sistemas sob custódia
- **Operacional** — interrupções na cadeia de fornecimento
- **Legal** — incumprimento regulatório do terceiro
- **Reputacional** — comportamentos do terceiro refletem na organização

Foco na Gestão do Risco – Motor do Planeamento

"One of the most important epiphanies a CISO can have is that they are not a technology manager, they are a risk manager."

O CISO deve avaliar o risco *cyber* em termos de negócio — linguagem que os executivos compreendem. Os riscos reais para a maioria das organizações incluem:



Perda de Clientes

Perda de clientes existentes e diminuição da capacidade de angariar novos.



Produtividade

Perda de produtividade por interrupções e custos de limpeza e controlo de danos.



Propriedade Intelectual

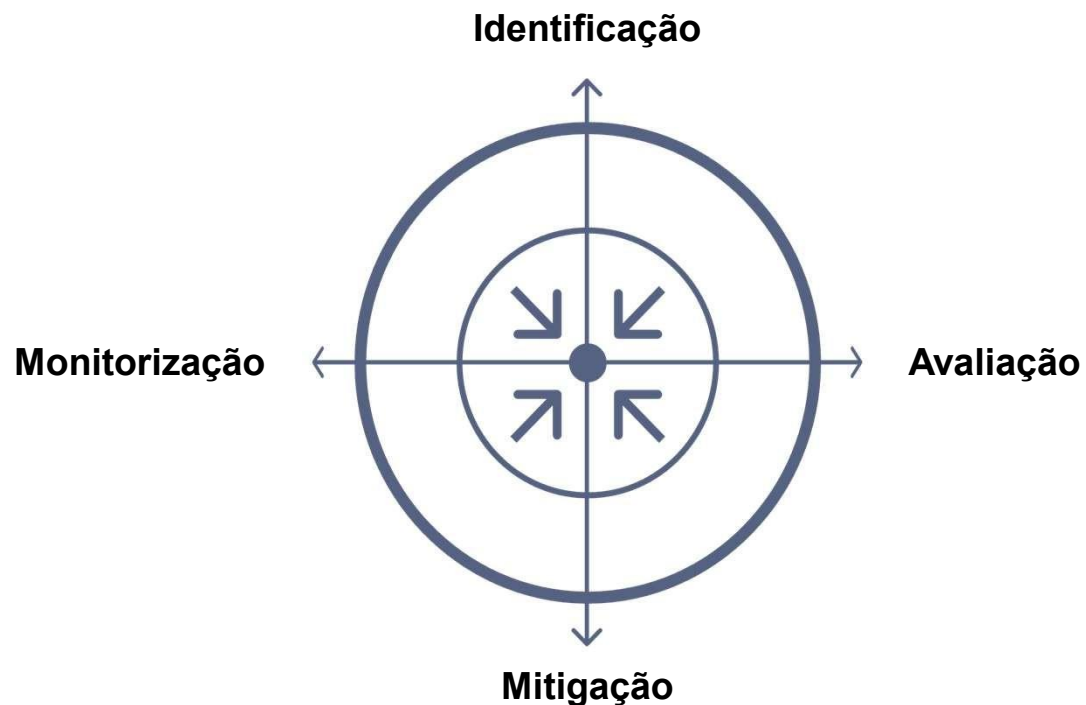
Roubo de propriedade intelectual com impacto direto na competitividade do negócio.

Planos de Mitigação de Risco

Um plano de mitigação de risco documenta as ações para reduzir o impacto de riscos identificados. Deve ser específico, realista, flexível e comunicado a todos os stakeholders relevantes.

O plano deve ser monitorizado regularmente:

- mudanças no ecossistema,
- fusões e aquisições,
- outros fatores podem tornar uma estratégia ineficaz e expor a necessidade de ajuste.



Ser Líder de Equipa



Construir uma equipa de cibersegurança forte é crucial. Pode ser uma equipa interna, totalmente externalizada (MSSP) ou um modelo híbrido. **A decisão deve considerar orçamento, maturidade organizacional e necessidades específicas.**

Definir Papéis e Responsabilidades

Clareza nos papéis ajuda a recrutar as pessoas certas e a definir expectativas realistas, incluindo níveis de senioridade.

Contratar as Pessoas Certas

Priorizar experiência relevante e competências técnicas. Não ignorar soft skills — comunicação, pensamento crítico e adaptabilidade

Cultura de Colaboração, Conhecimento e Inovação

Criar espaço para falhar e aprender. Manter a equipa desafiada, rodar papéis e promover autonomia e propriedade sobre soluções.

Gestão da Equipa - e liderança colaborativa

Manter o Envolvimento

- Manter a equipa focada com projetos interessantes
- Tirar pessoas da zona de conforto (ex: falar em público)
- Rodar papéis para evitar estagnação
- Promover autonomia e reconhecer conquistas
- Criar percursos de desenvolvimento de carreira
- **Gerir ambientes remotos colaborativos**
- **Gerir inteligência emocional do grupo**
- **Aplicar os padrões de comunicação de sucesso**



Gerir a mudança com instrumentos adequados ao desafio da complexidade

"Dá-me a serenidade para entender o que posso mudar, o que não posso, e a sabedoria para saber a diferença."

*A Oração da Serenidade de
São Tomás de Aquino*

Gestão da Equipa - e gestão da aprendizagem

Aprendizagem Contínua

- Subscrições a recursos e publicações de segurança
 - Participação em conferências e eventos
 - Formação regular e workshops especializados
 - Hackathons e partilha interna de conhecimento
 - Cyber Summit anual para unir funções diversas
- Gestão de Conhecimento em contexto Cyber
 - Desenvolvimento de competências não técnicas de forma regular
 - Adesão a comunidades e grupos especializados
 - Exercício Cyber Perseu
 - Participar enquanto Agente de Mudança nas comunidades CISO – do curso 😊

Ser Líder Executivo... e Colaborativo



01

Delegar e Colaborar

Dar autonomia (controlada) de decisão para os níveis adequados. É motor de motivação devendo existir o suporte adequado ao erro

02

Comunicação Aberta

Solicitar contributos proativamente, responder com transparência e partilhar o racional por detrás das decisões.

03

Definir Objetivos SMART

Colaborar para definir metas específicas, mensuráveis, alcançáveis, relevantes e com prazo, alinhadas com os objetivos de negócio.

04

Desenvolver a Equipa

Identificar lacunas de competências, investir em formação técnica e soft skills, e identificar futuros líderes o mais cedo possível.

Ser Defensor de GRC

Um CISO deve defender iniciativas de Governance, Risk and Compliance (GRC) para provar maturidade, navegar ambientes regulatórios complexos e fomentar uma cultura de integridade, conformidade e de gestão orientada ao risco e lógica de melhoria contínua

- ❑ Atenção: Conformidade não equivale a segurança. Um CISO eficaz vai além dos requisitos de conformidade.

Avaliação do Risco

Identificar, analisar e avaliar riscos. Apresentar impacto potencial e terminologia sobre o negócio

Políticas de Segurança

Definir regras claras sobre como a informação deve ser tratada — classificação, encriptação em repouso e em trânsito.

Controlos de Segurança

Mecanismos que aplicam as políticas — técnicos (WAF, IPS) ou administrativos (controlo de acessos, procedimentos de IR).

Governance & o Papel do CISO

Supervisão estratégica do Conselho

O *board* deve supervisionar iniciativas estratégicas cibersegurança, definir apetite de risco e garantir os recursos. O CISO é o gestor

Estrutura de Reporte Independente

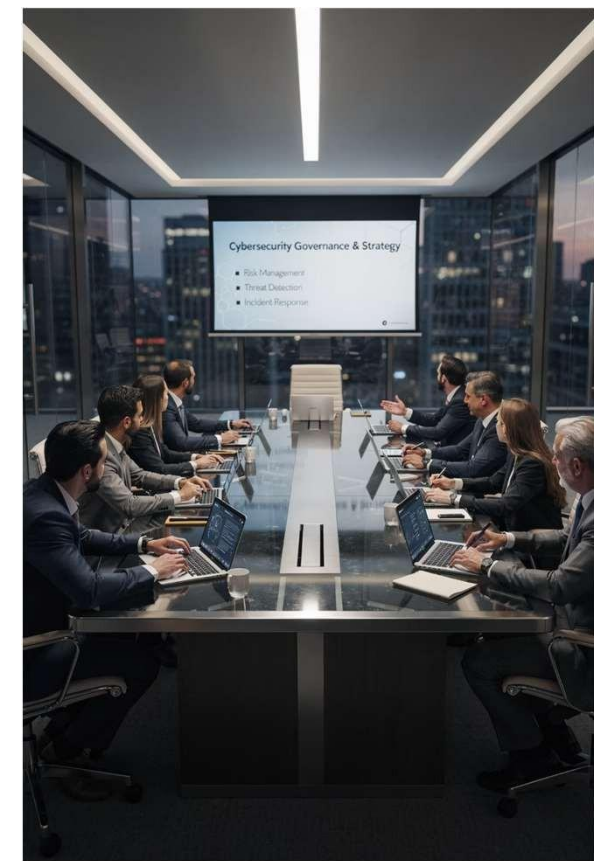
O CISO deve ter uma linha de reporte independente ao *board* para escalar questões críticas sem risco de retaliação.

Alinhamento Estratégico

A *governance* garante que as iniciativas do CISO estão alinhadas com os objetivos globais negócio — segurança como tema de negócio.

Comités de *Steering*

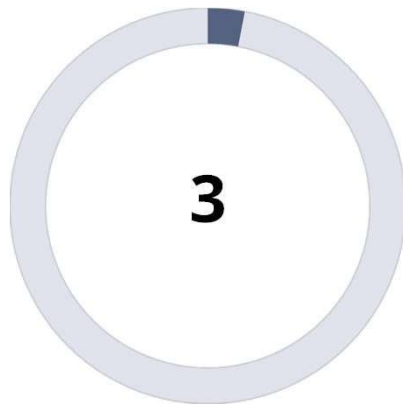
Sinal de maturidade de um programa de segurança. Devem incluir líderes seniores de legal, RGPD, TI, compliance, vendas e C-Suite.



Ser um Medidor

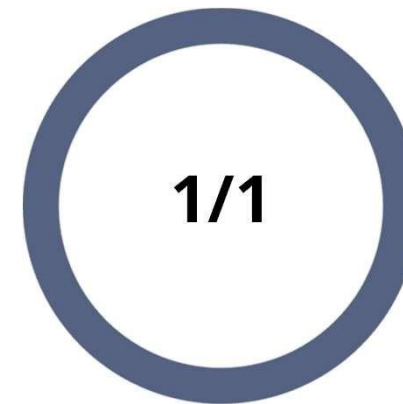
"Metrics need to paint a picture — they need to tell a story."

Medir e comunicar a eficácia dos programas de segurança é essencial para demonstrar valor, identificar lacunas e tomar decisões estratégicas baseadas em dados. O C-Suite e o conselho precisam de ver o risco *cyber* em termos de negócio, não em acrónimos e gráficos demasiado técnicos.



Audiências-Alvo

C-Suite, executivos seniores e membros do conselho — cada um com perspetivas distintas.



Subjetividade

Cada organização é única. O que importa para uma pode não importar para outra — as métricas devem ser contextuais.

Em síntese...

Não é um gestor de tecnologia — é um gestor da cibersegurança com foco no risco

O teu papel é fornecer expertise, suporte e conselho para que o negócio possa decidir quais os riscos a aceitar, mitigar, transferir ou evitar.

Conformidade não equivale a segurança

Um CISO eficaz vai além dos requisitos de conformidade e contribui ativamente para a proteção e resiliência real da organização.

Segurança é uma preocupação de negócio

Quando o risco *cyber* se traduz em risco de negócio, os líderes tornam-se mais recetivos a apoiar e financiar iniciativas de segurança.

A equipa é o maior ativo

Investir no envolvimento, competências e aprendizagem contínua da equipa é fundamental para o sucesso sustentado de qualquer programa de segurança.

Obrigado!